

POLÍTICA DE SEGURANÇA DA INFORMAÇÃO

e Diretrizes de Privacidade

Tubo Aço Indústria de Tubos Ltda.

Cenário: indústria de tubos com sistemas industriais conectados à internet

Documento controlado - Classificação: USO INTERNO

Documento	Política de Segurança da Informação (PSI) - Cenário 7
Revisão	1.0
Classificação	Uso interno
Elaboração (grupo)	Gabriel Gomes; Ricardo; Paulo: Projeto de Segurança II (PSII)
Aprovação	Comitê de Segurança da Informação / Direção - (assinatura) _____
Data de elaboração	01/06/2026
Início da vigência	12/06/2026
Próxima revisão	12/06/2027 (ou antes, em mudança relevante)

Sumário

Sumário.....	2
1. Introdução e Objetivo.....	3
2. Descrição do Ambiente / Cenário.....	3
3. Escopo e Aplicação.....	3
4. Referências Normativas.....	4
5. Termos e Definições.....	5
6. Gestão de Riscos.....	5
6.1 Tabela de Riscos.....	6
7. Procedimentos e Políticas Específicas.....	7
7.1 P-01: Controle de Acesso Físico e Lógico (segmentado por setor).....	7
7.2 P-02: Armazenamento e Criptografia de Dados Industriais.....	8
7.3 P-03: Tratamento e Descarte de Logs Operacionais.....	9
7.4 P-04: Política de Senhas para Operadores.....	10
7.5 P-05: Uso Restrito de Redes Sociais em Áreas Operacionais.....	11
7.6 P-06: Segurança na Convergência TI / OT / IoT.....	12
7.7 P-07: Gestão de Incidentes, Plano de Contingência e Continuidade.....	13
8. Penalidades por Violação.....	14
9. Divulgação, Conscientização e Ciência.....	14
10. Aprovação, Vigência e Revisão.....	14
Anexo A - Termo de Ciência e Responsabilidade.....	15
Anexo B - Declaração de Uso de Inteligência Artificial.....	16

1. Introdução e Objetivo

Esta Política de Segurança da Informação (PSI) estabelece as diretrizes, regras e responsabilidades para a proteção dos ativos de informação da Tubo Aço Indústria de Tubos Ltda., assegurando a confidencialidade, a integridade e a disponibilidade das informações e a proteção dos dados pessoais tratados pela organização.

O documento foi elaborado com base no processo de gestão de riscos e está alinhado às normas técnicas e à legislação aplicável, descritas na seção 4. Seu cumprimento é obrigatório para toda a força de trabalho.

2. Descrição do Ambiente / Cenário

A Tubo Aço Indústria de Tubos Ltda. é uma indústria de fabricação de tubos cujo parque produtivo possui sistemas industriais conectados à internet. O ambiente caracteriza-se pela convergência entre três domínios:

- **Tecnologia da Informação (TI):** rede corporativa, servidores, sistemas administrativos (ERP, e-mail), estações de trabalho e dados de negócio.
- **Tecnologia de Operação (OT) e IoT:** ambiente industrial (chão de fábrica) com controladores (CLP/PLC), supervisão (SCADA), sensores e dispositivos IoT que monitoram e controlam o processo de fabricação.
- **Operadores:** força de trabalho que opera as máquinas e os sistemas industriais, frequentemente em estações de chão de fábrica.

Essa convergência amplia a superfície de ataque: uma falha na rede de TI pode se propagar para a rede industrial (OT), e vice-versa. Os principais riscos a tratar são o acesso indevido à produção, a sabotagem dos sistemas industriais e os riscos decorrentes da integração TI × IoT, detalhados na seção 6.

3. Escopo e Aplicação

Esta política se aplica para toda a força de trabalho: colaboradores próprios (áreas administrativas, de TI e operadores de produção), estagiários, terceiros, prestadores de serviço e fornecedores com acesso a informações, sistemas ou instalações da organização - e abrange os ambientes de TI, OT e IoT, em instalações físicas e em acessos remotos.

4. Referências Normativas

As diretrizes desta política derivam das normas e da legislação a seguir. Em cada procedimento (seção 7) são citados os controles específicos utilizados.

Norma / referência	Aplicação nesta política
ABNT NBR ISO/IEC 27001:2022	Requisitos do SGSI. Aplicadas as cláusulas 4 (contexto), 5 (liderança e política), 6.1 (ações para abordar riscos), 7.2/7.3 (competência e conscientização), 7.5 (informação documentada), 8 (operação), 9 (avaliação de desempenho) e 10 (melhoria).
ABNT NBR ISO/IEC 27002:2022	Catálogo de controles. Procedimentos referenciam controles dos 4 temas: organizacional (5.x), pessoas (6.x), físico (7.x) e tecnológico (8.x).
ABNT NBR ISO/IEC 27005:2023	Orientações para a gestão de riscos de segurança da informação, base da seção 6 (identificação, análise, avaliação e tratamento de riscos).
ABNT NBR ISO 31000:2018	Princípios e processo de gestão de riscos (estrutura adotada na metodologia da seção 6).
ABNT NBR ISO/IEC 27557:2023	Gestão de riscos de privacidade organizacional, aplicada ao tratamento de dados pessoais (ex.: logs e dados de operadores).
LGPD - Lei nº 13.709/2018	Princípios e bases legais (art. 6º e 7º), medidas de segurança (art. 46/47), término do tratamento (art. 15/16), comunicação de incidentes (art. 48) e sanções (art. 52).

5. Termos e Definições

- **Ativo de informação:** informação ou recurso que armazena, processa, transmite ou suporta informações e que possui valor para a organização.
- **Ameaça:** causa potencial de um incidente capaz de explorar vulnerabilidades e causar danos à organização.
- **Vulnerabilidade:** fraqueza ou deficiência de um ativo, processo ou controle que pode ser explorada por uma ameaça.
- **Risco:** efeito da incerteza sobre os objetivos da organização, normalmente avaliado pela combinação entre probabilidade e impacto.
- **Incidente de segurança da informação:** evento que compromete ou tem potencial de comprometer a confidencialidade, integridade ou disponibilidade das informações.
- **TI / OT / IoT:** Tecnologia da Informação; Tecnologia de Operação utilizada para monitorar e controlar processos industriais; e Internet das Coisas, composta por dispositivos conectados capazes de coletar, transmitir ou processar dados.
- **Dados pessoais (DP):** informação relacionada a pessoa natural identificada ou identificável, conforme a LGPD.

6. Gestão de Riscos

A gestão de riscos segue o processo da ABNT NBR ISO 31000:2018, especializado para segurança da informação pela ABNT NBR ISO/IEC 27005:2023: identificar, analisar, avaliar, tratar e monitorar. O nível de risco é obtido pela combinação de Probabilidade (P) e Impacto (I), ambos em escala de 1 a 5:

Nível de Risco = Probabilidade × Impacto

Baixo: 1 a 4 | Médio: 5 a 9 | Alto: 10 a 14 | Crítico: 15 a 25

A tabela a seguir consolida os riscos identificados para o cenário, com a opção de tratamento (mitigar) e os controles da ISO/IEC 27002:2022 que os endereçam - os mesmos refletidos nos procedimentos da seção 7 e na Declaração de Aplicabilidade do SGSI.

6.1 Tabela de Riscos

ID	Ativo / Processo	Ameaça	Vulnerabilidade	P	I	Nível	Tratamento e controles ISO/IEC 27002:2022
R-01	Acesso à área de produção	Pessoa não autorizada / insider	Ausência de segmentação de acesso por setor	3	5	Crítico	Mitigar: 5.15, 5.18, 7.2, 8.3
R-02	Sistemas industriais (OT/SCADA)	Sabotagem (agente interno/externo)	Rede OT sem segmentação e sem monitoramento	2	5	Alto	Mitigar: 8.22, 8.16, 5.26, 7.6
R-03	Convergência TI ↔ IoT/OT	Movimento lateral da TI para a OT	Integração sem DMZ industrial entre as redes	3	4	Alto	Mitigar: 8.22, 8.20, 8.9, 8.8
R-04	Dados industriais (projetos/PI)	Exfiltração / vazamento de dados	Dados sem criptografia e sem classificação	3	4	Alto	Mitigar: 8.24, 5.12, 8.12
R-05	Sistema industrial crítico	Falha / ransomware	Falta de redundância e de backup testado	3	4	Alto	Mitigar: 8.13, 8.14, 5.30, 8.7
R-06	Credenciais de operadores	Acesso não autorizado	Senhas fracas e contas compartilhadas	4	4	Crítico	Mitigar: 5.17, 8.5, 5.16
R-07	Estações em área operacional	Engenharia social / malware	Acesso irrestrito a redes sociais na OT	3	3	Médio	Mitigar: 5.10, 8.23, 8.1
R-08	Logs operacionais	Perda de evidência / exposição de dados	Sem política de retenção e descarte seguro	3	3	Médio	Mitigar: 8.15, 7.14, 8.10, 5.33

7. Procedimentos e Políticas Específicas

Cada procedimento abaixo é um documento controlado, com finalidade, autoria, versão, aprovação e vigência próprias. A autoria está distribuída entre os membros do grupo (segregação de funções).

7.1 P-01: Controle de Acesso Físico e Lógico (segmentado por setor)

Finalidade / Objetivo	Garantir que o acesso físico e lógico às instalações, sistemas e dados ocorra apenas por pessoas autorizadas, conforme a função, segmentado por setor.
Autoria	Gabriel Gomes - Setor de TI/Segurança - 01/06/2026
Revisão	1.0
Aprovação	Comitê de Segurança da Informação - 10/06/2026
Vigência	Início 12/06/2026; validade 12 meses (revisão até 12/06/2027)

Acesso físico

- Áreas segregadas por setor: administrativo, produção (chão de fábrica) e ambiente crítico (sala de servidores e sala de controle/SCADA), com autorização conforme a função.
- Entrada por crachá individual; biometria nas áreas críticas. Registro (log) de entrada/saída retido conforme o P-03.
- Visitantes e terceiros: identificação, autorização prévia e acompanhamento; é vedado o acesso desacompanhado à produção.
- Revisão trimestral das autorizações de acesso físico e bloqueio automático das portas.

Acesso lógico

- Controle de acesso baseado em papéis (RBAC), segmentado por setor, com menor privilégio e segregação de funções.
- Contas individuais e nominais; o compartilhamento de credenciais é proibido.
- Autenticação multifator (MFA) obrigatória para acessos privilegiados, acesso remoto e a sistemas OT/SCADA.
- Concessão, alteração e revogação por processo formal, com revogação imediata no desligamento; revisão dos direitos no mínimo semestral.

Base normativa: ISO/IEC 27002:2022 - 5.3, 5.15, 5.16, 5.17, 5.18, 7.1, 7.2, 7.3, 7.4, 7.6, 8.2, 8.3, 8.5; ISO/IEC 27001:2022 - 6.1 e 8; LGPD - art. 46.

Riscos tratados: R-01, R-02, R-06.

7.2 P-02: Armazenamento e Criptografia de Dados Industriais

Finalidade / Objetivo	Proteger os dados industriais (parâmetros de processo, projetos e propriedade intelectual) em repouso e em trânsito, por meio de classificação e criptografia.
Autoria	Ricardo - Setor de TI/Infraestrutura - 01/06/2026
Revisão	1.0
Aprovação	Comitê de Segurança da Informação - 10/06/2026
Vigência	Início 12/06/2026; validade 12 meses (revisão até 12/06/2027)

- Classificação dos dados industriais em público, interno, confidencial e restrito, conforme a sensibilidade.
- Criptografia em repouso: AES-256 para bancos de dados, servidores de arquivos, backups e mídias removíveis que contenham dados confidenciais ou restritos.
- Criptografia em trânsito: TLS 1.2 ou superior (preferencialmente 1.3) nas comunicações entre sistemas; VPN com criptografia forte para acesso remoto.
- Gestão de chaves: chaves protegidas em cofre/HSM, com rotação periódica, custódia e segregação entre quem administra dados e quem administra chaves.
- Backups criptografados, com cópia externa (off-site) e testes de restauração periódicos (integra o P-07).
- Transferência de dados a terceiros apenas por canais cifrados e mediante acordo de confidencialidade.

Base normativa: ISO/IEC 27002:2022 - 5.12, 5.14, 5.33, 8.13, 8.24; ISO/IEC 27001:2022 - 8; LGPD - art. 46 e 47.

Riscos tratados: R-04, R-05.

7.3 P-03: Tratamento e Descarte de Logs Operacionais

Finalidade / Objetivo	Definir a geração, proteção, retenção e o descarte seguro dos logs de TI e OT, preservando evidências e atendendo à LGPD.
Autoria	Paulo - Setor de TI/Segurança - 01/06/2026
Revisão	1.0
Aprovação	Comitê de Segurança da Informação - 10/06/2026
Vigência	Início 12/06/2026; validade 12 meses (revisão até 12/06/2027)

- Geração de logs em sistemas de TI e OT (acessos, eventos de segurança e operações críticas), com sincronização de relógio (NTP) para correlação.
- Proteção da integridade dos logs: acesso restrito, modo somente leitura e proteção contra adulteração.
- Retenção: período definido (referência: 6 meses on-line e 12 meses em arquivo), ajustável a requisitos legais e contratuais. Logs com dados pessoais seguem a LGPD (minimização e finalidade).
- Monitoramento e análise periódica dos logs para detecção de eventos (integra o P-07).
- Descarte seguro: após a retenção, exclusão lógica segura dos dados e sanitização/destruição das mídias físicas, com registro do descarte. O descarte ad hoc por operadores é proibido.

Base normativa: ISO/IEC 27002:2022 - 5.33, 5.34, 7.14, 8.10, 8.15, 8.16, 8.17; ISO/IEC 27001:2022 - 8 e 9; ISO/IEC 27557:2023 (privacidade); LGPD - art. 15, 16 e 46.

Riscos tratados: R-08.

7.4 P-04: Política de Senhas para Operadores

Finalidade / Objetivo	Estabelecer regras de criação, uso e proteção de senhas, com tratamento específico para as estações de chão de fábrica.
Autoria	Gabriel Gomes - Setor de TI/Segurança - 01/06/2026
Revisão	1.0
Aprovação	Comitê de Segurança da Informação - 10/06/2026
Vigência	Início 12/06/2026; validade 12 meses (revisão até 12/06/2027)

- Tamanho mínimo de 12 caracteres com complexidade (maiúsculas, minúsculas, números e símbolos); senhas óbvias ou reutilizadas são proibidas.
- Troca imediata em caso de suspeita de comprometimento; é vedado compartilhar ou anotar senhas de forma visível (integra mesa limpa e tela limpa).
- Bloqueio de conta após número definido de tentativas malsucedidas e bloqueio de sessão por inatividade.
- MFA onde tecnicamente viável, especialmente para sistemas de produção e acessos remotos.
- Estações compartilhadas de chão de fábrica: login nominal sempre que possível; quando inevitável o uso em quiosque, registrar o operador responsável por turno e restringir privilégios.
- Credenciais de serviço guardadas em cofre de senhas; o hardcoding de senhas é proibido.

Base normativa: ISO/IEC 27002:2022 - 5.16, 5.17, 7.7, 8.5; ISO/IEC 27001:2022 - 8; LGPD - art. 46.

Riscos tratados: R-06.

7.5 P-05: Uso Restrito de Redes Sociais em Áreas Operacionais

Finalidade / Objetivo	Restringir o uso de redes sociais em áreas operacionais para reduzir vetores de ataque e o risco de vazamento de informações.
Autoria	Ricardo - Setor de TI/Segurança - 01/06/2026
Revisão	1.0
Aprovação	Comitê de Segurança da Informação - 10/06/2026
Vigência	Início 12/06/2026; validade 12 meses (revisão até 12/06/2027)

- Acesso a redes sociais e a mensageiros pessoais é proibido nas estações de áreas operacionais e em sistemas OT.
- Filtragem de conteúdo web (bloqueio de categorias de risco) nas redes corporativa e operacional.
- Uso restrito de dispositivos pessoais em áreas operacionais, por razões de segurança da informação e de segurança do trabalho; câmeras restritas em áreas sensíveis.
- Conscientização sobre redes sociais como vetor de engenharia social, phishing e vazamento de informações.
- Exceções (ex.: marketing) somente em estações segregadas da rede administrativa e mediante autorização.

Base normativa: ISO/IEC 27002:2022 - 5.10, 6.3, 8.1, 8.23; ISO/IEC 27001:2022 - 7.3 e 8.

Riscos tratados: R-07.

7.6 P-06: Segurança na Convergência TI / OT / IoT

Finalidade / Objetivo	Proteger a integração entre a rede de TI e o ambiente industrial (OT/IoT), prevenindo movimento lateral, acesso indevido e sabotagem.
Autoria	Paulo: Setor de TI/Infraestrutura - 01/06/2026
Revisão	1.0
Aprovação	Comitê de Segurança da Informação: 10/06/2026
Vigência	Início 12/06/2026; validade 12 meses (revisão até 12/06/2027)

- Segmentação de redes: separação lógica e física entre rede corporativa (TI), rede industrial (OT) e dispositivos IoT, com zona desmilitarizada (DMZ) industrial e firewall entre zonas (modelo de zonas / Purdue).
- Inventário atualizado de todos os ativos de TI, OT e IoT; nenhum dispositivo não inventariado pode ser conectado.
- Hardening e gestão de configuração segura dos dispositivos industriais e IoT (desativar serviços e portas desnecessários, alterar senhas padrão).
- Gestão de vulnerabilidades técnicas com janelas de manutenção planejadas para OT e aplicação controlada de correções.
- Acesso remoto à OT restrito e monitorado (somente via jump server na DMZ, com MFA e sessão registrada).
- Monitoramento contínuo do tráfego entre TI e OT para detectar movimento lateral e anomalias; uso de inteligência de ameaças do setor industrial.

Base normativa: ISO/IEC 27002:2022 - 5.7, 5.9, 8.8, 8.9, 8.16, 8.20, 8.21, 8.22; ISO/IEC 27001:2022 - 6.1 e 8.

Riscos tratados: R-02, R-03.

7.7 P-07: Gestão de Incidentes, Plano de Contingência e Continuidade

Finalidade / Objetivo	Detectar, responder e recuperar de incidentes de segurança e assegurar a continuidade da operação industrial durante interrupções.
Autoria	Equipe / Comitê de SI: Gabriel Gomes Galikosky, Ricardo André e Paulo José de Oliveira Rolinski - 01/06/2026
Revisão	1.0
Aprovação	Comitê de Segurança da Informação: 10/06/2026
Vigência	Início 12/06/2026; validade 12 meses (revisão até 12/06/2027)

- Canal e procedimento para reporte tempestivo de eventos e incidentes por qualquer colaborador.
- Classificação, contenção, erradicação e recuperação de incidentes, com escalonamento definido.
- Plano de contingência (reação imediata): isolar o sistema/segmento afetado, acionar servidor ou linha reserva e comunicar as partes interessadas.
- Plano de continuidade: manter a operação industrial essencial durante a interrupção (redundância, backups testados e prontidão de TIC).
- Coleta e preservação de evidências para apuração e eventual responsabilização.
- Comunicação à ANPD e aos titulares em incidentes com dados pessoais, quando aplicável; registro de lições aprendidas.

Base normativa: ISO/IEC 27002:2022 - 5.24, 5.25, 5.26, 5.27, 5.28, 5.29, 5.30, 6.8, 8.13, 8.14; ISO/IEC 27001:2022 - 8 e 10; LGPD - art. 48.

Riscos tratados: R-02 e R-05 (resposta); todos (resiliência).

8. Penalidades por Violação

O descumprimento desta política e de seus procedimentos sujeita o infrator a medidas disciplinares, apuradas por meio de processo disciplinar formal que assegure o contraditório e a proporcionalidade entre a sanção e a gravidade da conduta.

A gradação observa a gravidade e a reincidência:

- **Leve:** orientação ou advertência verbal.
- **Moderada:** advertência por escrito.
- **Grave:** suspensão.
- **Gravíssima ou reincidente:** rescisão por justa causa (CLT, art. 482), sem prejuízo da responsabilização civil e criminal cabível.
- **Terceiros e fornecedores:** notificação, suspensão e rescisão contratual, conforme as cláusulas de segurança da informação dos contratos.

A aplicação de qualquer penalidade está condicionada à comprovação de que o infrator teve ciência prévia desta política (seção 9).

Base normativa: ISO/IEC 27002:2022 - 6.4 (processo disciplinar), 5.20 (contratos de fornecedores); CLT - art. 482.

9. Divulgação, Conscientização e Ciência

Para que as penalidades sejam aplicáveis, a organização garante a ampla divulgação desta política e o registro da ciência por parte de toda a força de trabalho utilizando meios adequados ao público, inclusive os operadores de chão de fábrica.

- Assinatura do Termo de Ciência e Responsabilidade (Anexo A) no ingresso e a cada revisão relevante da política.
- Treinamento de integração (admissional) e reciclagem periódica, no mínimo anual, com registros mantidos como evidência.
- Divulgação por múltiplos canais: intranet, e-mail corporativo, murais e comunicados no chão de fábrica (linguagem acessível) e diálogos de segurança.
- A política permanece disponível e versionada; mudanças são comunicadas formalmente.
- A ciência registrada é condição para a aplicação de penalidades (seção 8).

Base normativa: ISO/IEC 27002:2022 - 5.37, 6.2, 6.3, 6.4; ISO/IEC 27001:2022 - 7.3 (conscientização).

10. Aprovação, Vigência e Revisão

Esta política entra em vigor em 12/06/2026, tem validade de 12 meses e deve ser revisada ao menos anualmente ou diante de mudança relevante (novo risco, incidente significativo, alteração tecnológica ou legal). É um documento controlado, com histórico de versões mantido.

Aprovado por: _____ Data: ____/____/____

Comitê de Segurança da Informação / Direção

Anexo A - Termo de Ciência e Responsabilidade

Declaro que recebi, li e compreendi a Política de Segurança da Informação da Tubo Aço Indústria de Tubos Ltda. (versão 1.0) e os procedimentos a ela vinculados, comprometendo-me a cumpri-los integralmente. Estou ciente de que o descumprimento sujeita-se às penalidades previstas na seção 8, sem prejuízo das responsabilidades civis e criminais aplicáveis.

Nome: _____

Setor / Função: _____

Matrícula: _____ Data: ____/____/____

Assinatura: _____

Anexo B - Declaração de Uso de Inteligência Artificial

Em atendimento aos requisitos do Projeto de Segurança II, o grupo declara que utilizou inteligência artificial como apoio de redação, estruturação e revisão deste documento.

Ferramenta / Modelo	Claude (Anthropic), acessado via claude.ai / Modelo Fable 5
Forma de uso	Design visual das tabelas (aplicação de cores, índices e cabeçalhos); correção de erros ortográficos, eliminação de linguagem informal e ajustes para padronização e clareza.
Revisão humana	Todo o conteúdo foi lido, ajustado e validado pelos três integrantes do grupo antes da entrega.

Principais prompts utilizados:

- "Aplique design visual com cores nos cabeçalhos e índices das tabelas (azul/cinza) conforme contexto industrial, e corrija erros ortográficos e linguagem para clareza "
- "Aplique design visual com cores nos cabeçalhos e índices das tabelas (azul/cinza) conforme contexto industrial. Corrija erros ortográficos em todo o documento, elimine expressões informais e padronize a linguagem técnica para registro formal e profissional."